

DEVOPS E ARQUITETURA CLOUD

FASE 3 | AULA 05 -

FERRAMENTAS DE CSPM, CWPP E CASB

SUMÁRIO

O QUE VEM POR AÍ?	3
HANDS ON	4
SAIBA MAIS.....	5
MERCADO, CASES E TENDÊNCIAS	19
O QUE VOCÊ VIU NESTA AULA?	20
REFERÊNCIAS.....	21

O QUE VEM POR AÍ?

Esta aula vai apresentar uma jornada completa pelas três ferramentas fundamentais que revolucionaram a segurança em ambientes de nuvem: Cloud Security Posture Management (CSPM), Cloud Workload Protection Platform (CWPP) e Cloud Access Security Broker (CASB).

Você vai entender não apenas o que cada ferramenta faz, mas como elas se integram para formar uma estratégia de defesa robusta e abrangente. Ao final desta aula, você será capaz de explicar as funções essenciais de cada ferramenta, identificar como elas detectam e mitigam riscos específicos, e avaliar cenários práticos de implementação em organizações reais.

HANDS ON

Nessa videoaula, teremos um hands on de segurança em cloud. O objetivo é demonstrar, de maneira aplicada e didática, como integrar diferentes camadas de proteção em um ambiente multicloud.

Ao longo dos vídeos, você acompanhará a simulação de três pilares fundamentais: CSPM (Cloud Security Posture Management), para monitorar e corrigir configurações incorretas; CWPP (Cloud Workload Protection Platform), para proteger cargas de trabalho críticas em execução; e CASB (Cloud Access Security Broker), para controlar o uso de aplicações SaaS e mitigar riscos de Shadow IT.

Cada atividade foi organizada em passos claros, com exemplos de ferramentas open source e cenários práticos que ilustram como essas soluções podem ser aplicadas em empresas modernas que buscam segurança abrangente na nuvem.

SAIBA MAIS

A digitalização acelerou significativamente a adoção de soluções em cloud, mudando de forma crucial o cenário da segurança nas empresas. De acordo com estudos recentes, 87% das empresas operam em ambientes MultiCloud e 72% implementam táticas de cloud híbrida. Essa transição em larga escala trouxe vantagens incontáveis, como maior agilidade, escalabilidade e inovação, mas também apresentou novas complexidades em termos de segurança.

O modelo convencional de proteção, que se baseia em fronteiras de rede bem definidas e controles centralizados, já não é eficaz para salvaguardar infraestruturas distribuídas, aplicações desenvolvidas especificamente para a cloud e dados distribuídos entre diversos provedores de serviços. A superfície vulnerável aumentou de forma drástica, gerando novos vetores de ameaças que requerem soluções inovadoras de proteção.

Por que CSPM, CWPP e CASB se tornaram importantes? A solução está na natureza dos problemas relacionados à segurança na cloud. Em primeiro lugar, a configuração da infraestrutura tornou-se incrivelmente complexa, com milhares de recursos sendo alocados dinamicamente por meio de APIs.

Em segundo lugar, as cargas de trabalho operam em ambientes que são tanto efêmeros quanto abstratos, que vão desde máquinas virtuais convencionais até contêineres e funções sem servidor. Em terceiro lugar, o acesso a dados e aplicações é feito por meio de uma variedade de serviços SaaS, frequentemente fora do controle direto da empresa.

Cada uma dessas facetas exige uma abordagem de segurança específica. O CSPM aborda a primeira faceta, assegurando que a infraestrutura esteja configurada adequadamente e em conformidade. O CWPP defende a segunda faceta, monitorando e protegendo as cargas de trabalho ativas. O CASB regula a terceira faceta, controlando a forma como os usuários acessam e utilizam os serviços em cloud.

A ausência dessas ferramentas especializadas expõe as organizações a riscos críticos que podem resultar em violações de dados, interrupções de serviço e não conformidade regulatória.

O Shadow IT representa um dos riscos mais complicados e você já deve ter passado por isso. Funcionários frequentemente adotam aplicações SaaS não sancionadas para aumentar sua produtividade, criando pontos cegos para as equipes de segurança.

Dados corporativos sensíveis podem ser armazenados em serviços não controlados, compartilhados inadequadamente ou acessados por dispositivos não gerenciados. Sem visibilidade e controle adequados, as organizações ficam vulneráveis a vazamentos de dados e violações de conformidade.

Os workloads com vulnerabilidades representam outro foco de risco importante. Programas rodando em plataformas de nuvem podem apresentar falhas de software, configurações inadequadas ou comportamentos estranhos que não são detectados por ferramentas de segurança convencionais. Contêineres podem ser lançados com imagens que incluem malware ou brechas já conhecidas. Funções sem servidor podem ser aproveitadas para executar código nocivo ou acessar recursos sem autorização.

Erros na configuração da infraestrutura de cloud são responsáveis por uma parte considerável das violações de dados. Armazenamentos configurados para acesso público, grupos de segurança com diretrizes excessivamente liberais, chaves de criptografia mal administradas e permissões de identidade excessivas são exemplos comuns de configurações erradas que atacantes podem explorar.

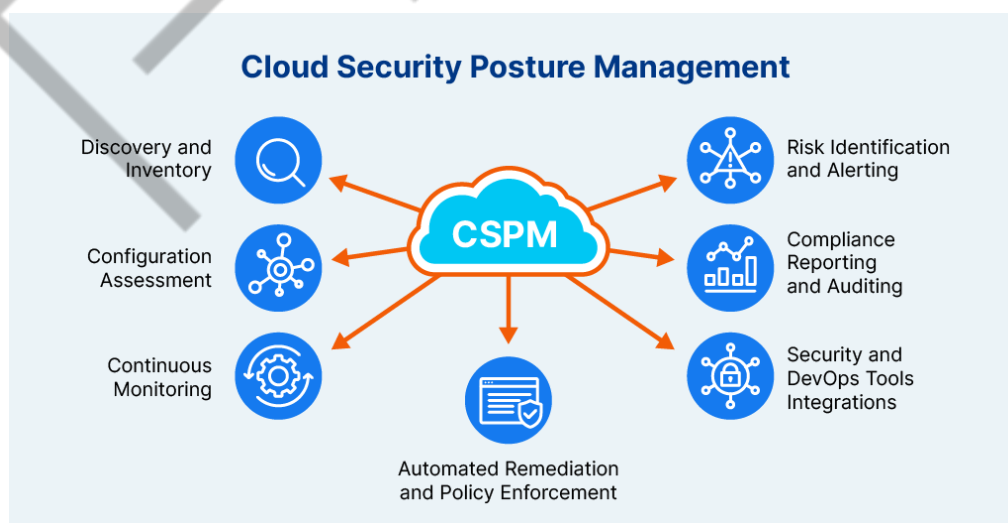


Figura 1 – Cloud Security Posture Management (CSPM)
Fonte: Appomni (2024)

O Cloud Security Posture Management representa a evolução natural das práticas de auditoria e conformidade para o ambiente de nuvem. Conforme definido pela IBM, o CSPM é uma categoria de soluções que automatiza a descoberta, avaliação e correção de riscos de configuração em infraestruturas de cloud, proporcionando visibilidade contínua e governança de segurança em escala empresarial.

O CSPM funciona como um sistema de monitoramento contínuo que se conecta às APIs dos provedores de nuvem para descobrir automaticamente todos os recursos implantados, catalogar suas configurações e compará-las contra um conjunto abrangente de políticas de segurança e conformidade.

As principais funções do CSPM incluem a descoberta automatizada de ativos, que enumera todos os recursos de nuvem em tempo real, desde máquinas virtuais e bancos de dados até funções serverless e configurações de rede. O sistema mantém um inventário dinâmico que reflete o estado atual da infraestrutura, eliminando os pontos cegos que frequentemente existem em ambientes de nuvem complexos.

A avaliação contínua de configurações compara o estado atual dos recursos contra benchmarks estabelecidos como CIS (Center for Internet Security), NIST (National Institute of Standards and Technology) e frameworks regulatórios específicos como PCI DSS, HIPAA e GDPR. Qualquer desvio das configurações recomendadas é imediatamente identificado e classificado por nível de risco.

O CSPM concentra-se em três áreas fundamentais que formam a base da segurança em cloud. A configuração correta garante que todos os recursos estejam configurados de acordo com as melhores práticas de segurança. Isso inclui verificações como garantir que buckets de armazenamento não estejam publicamente acessíveis, que grupos de segurança não tenham regras excessivamente permissivas e que a criptografia esteja habilitada para dados em trânsito e em repouso.

A conformidade regulatória é automatizada através da implementação de políticas que refletem requisitos específicos de diferentes frameworks. Por exemplo, para organizações sujeitas ao GDPR, o CSPM pode verificar se os dados pessoais

estão sendo armazenados em regiões geográficas apropriadas e se os controles de acesso adequados estão implementados.

A postura de segurança geral é avaliada através de métricas agregadas que fornecem uma visão holística do nível de segurança da infraestrutura. Essas métricas permitem que as equipes de segurança priorizem esforços de remediação e demonstrem melhorias ao longo do tempo.

Os alertas mais frequentes gerados por soluções CSPM refletem as configurações incorretas mais comuns e perigosas encontradas em ambientes de nuvem. Permissões públicas em buckets de armazenamento representam uma das configurações incorretas mais críticas, pois podem resultar na exposição de dados sensíveis diretamente na internet.

O CSPM detecta quando buckets S3, Azure Blob Storage ou Google Cloud Storage são configurados com acesso público de leitura ou escrita. Chaves de acesso expostas constituem outro alerta crítico. Isso inclui chaves de API, senhas e certificados que podem estar hardcoded em código-fonte, armazenados em repositórios públicos ou configurados com permissões excessivas.

O CSPM pode detectar essas exposições através da análise de configurações de recursos e integração com sistemas de controle de versão.

Grupos de segurança com regras permissivas são frequentemente alertados, especialmente quando permitem acesso SSH (porta 22) ou RDP (porta 3389) de qualquer endereço IP (0.0.0.0/0). Essas configurações criam vetores de ataque diretos para recursos computacionais.

Recursos sem criptografia representam violações de conformidade em muitos frameworks regulatórios. O CSPM alerta quando bancos de dados, volumes de armazenamento ou canais de comunicação não estão utilizando criptografia adequada.

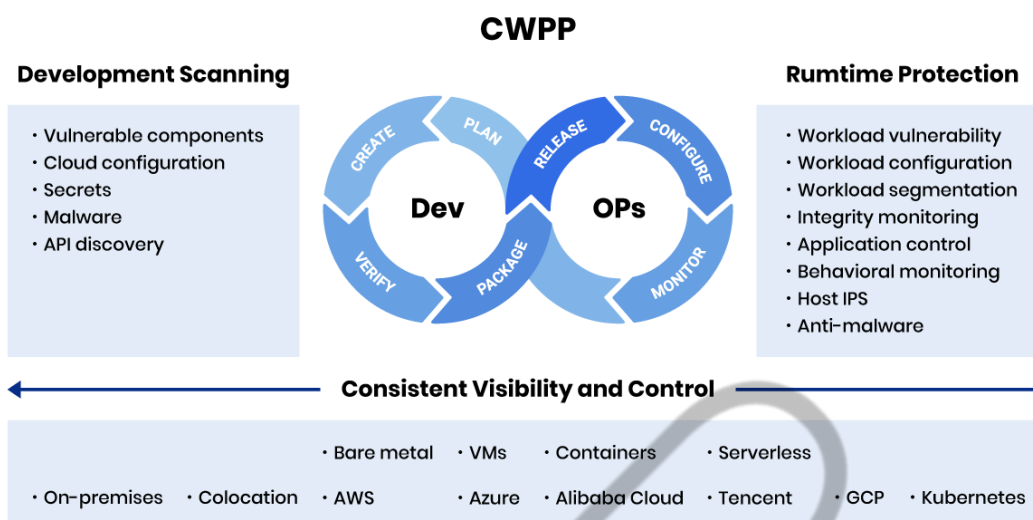


Figura 2 – What Is a Cloud Workload Protection Platform (CWPP)
Fonte: Tigera.io (2024)

A CWPP (Cloud Workload Protection Platform) representa uma evolução das soluções tradicionais de proteção de endpoint para atender às necessidades específicas de cargas de trabalho em cloud. Conforme definido pela Cloudflare, uma CWPP é uma ferramenta de segurança que detecta e remove ameaças dentro do software em cloud, funcionando como um sistema de proteção interno que monitora e protege cargas de trabalho em execução.

Falamos da proteção de workoadas como VMS, containers e serveless. Hoje, com a diversidade de tipos de cargas de trabalho em ambientes de nuvem, são necessárias abordagens de proteção especializadas. Máquinas virtuais tradicionais executam sistemas operacionais completos e podem hospedar múltiplas aplicações simultaneamente.

A proteção dessas cargas de trabalho envolve a instalação de agentes que monitoram processos, conexões de rede, alterações no sistema de arquivos e comportamento geral do sistema. Contêineres apresentam desafios únicos devido à sua natureza efêmera e densidade. Uma única máquina host pode executar centenas de contêineres, cada um com seu próprio ambiente isolado.

A CWPP deve ser capaz de monitorar atividades dentro de cada contêiner individualmente, analisar imagens de contêiner em busca de vulnerabilidades antes da implantação e aplicar políticas de segurança específicas para ambientes com containers.

Funções serverless operam em um modelo completamente diferente, onde o código é executado em resposta a eventos específicos em um ambiente gerenciado pelo provedor de nuvem. A proteção dessas cargas de trabalho requer instrumentação do código da função, análise de dependências e monitoramento de comportamento durante a execução.

O monitoramento de vulnerabilidades na CWPP opera em múltiplas camadas e momentos do ciclo de vida da carga de trabalho. Durante a fase de desenvolvimento e construção, a CWPP escaneia imagens de contêiner, pacotes de software e dependências em busca de vulnerabilidades conhecidas (CVEs). Este processo de scanning estático identifica problemas antes que as cargas de trabalho sejam implantadas em produção.

Durante a execução (runtime), a CWPP monitora continuamente o comportamento das cargas de trabalho para detectar atividades suspeitas ou maliciosas. Isso inclui a execução de processos não autorizados, conexões de rede anômalas, modificações não autorizadas de arquivos e tentativas de escalação de privilégios.

O monitoramento de runtime utiliza técnicas avançadas como análise comportamental baseada em Machine Learning para estabelecer baselines de comportamento normal e detectar desvios que podem indicar comprometimento. A CWPP também implementa proteções em tempo real, como prevenção de exploits de memória e controles de integridade de arquivos.

Agora, falando de um exemplo, podemos citar uma proteção de Kubernetes e VMs na cloud. Em um ambiente Kubernetes, a CWPP implementa proteção em múltiplas camadas. No nível do cluster, a solução monitora a API do Kubernetes para detectar configurações inseguras, como pods executando com privilégios excessivos ou políticas de rede permissivas.

No nível do nó, agentes monitoram o sistema operacional host e o runtime de contêiner. Para cada pod individual, a CWPP analisa a imagem do contêiner antes da implantação, verificando vulnerabilidades conhecidas e configurações inseguras. Durante a execução, a solução monitora processos, conexões de rede e acesso a arquivos dentro de cada contêiner.

Em máquinas virtuais, a CWPP instala agentes que operam no nível do sistema operacional, proporcionando visibilidade completa sobre todas as atividades do sistema. Esses agentes monitoram processos em execução, conexões de rede, alterações no registro (em sistemas Windows) ou arquivos de configuração (em sistemas Linux) e atividades de usuários.

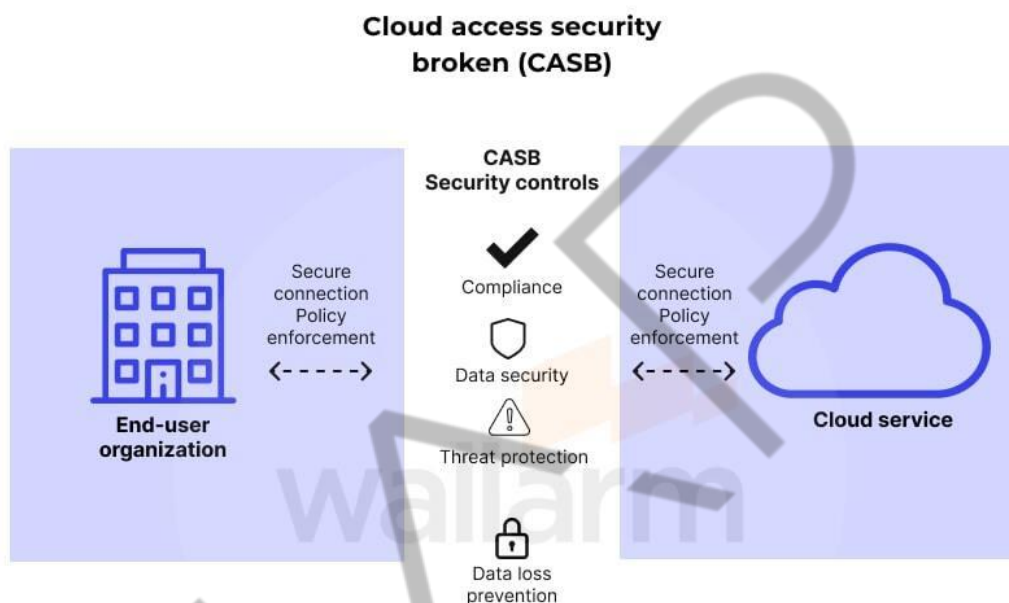


Figura 3 – Cloud Access Security Broker Architecture (CASB)
Fonte: Tigera.io (2024)

O Cloud Access Security Broker funciona como um ponto de controle de políticas de segurança posicionado entre os usuários corporativos e os provedores de serviços em cloud. Conforme definido pela Netskope, o CASB atua como um intermediário que garante que o acesso aos dados e aplicações em cloud esteja em conformidade com as políticas de segurança organizacionais.

A função de mediação do CASB é fundamental para manter controle e visibilidade sobre como os usuários interagem com aplicações SaaS. Em um modelo tradicional de TI, todas as aplicações corporativas executavam dentro do perímetro controlado da organização. Com a adoção massiva de SaaS, dados corporativos agora residem em sistemas externos, acessados através da internet por usuários em localizações diversas usando uma variedade de dispositivos.

O CASB atua como um proxy inteligente que pode interceptar, analisar e controlar todas as interações entre usuários e serviços em cloud. Esta mediação

pode ocorrer em tempo real (modo proxy) ou através de análise retroativa (modo API), dependendo dos requisitos de segurança e operacionais da organização.

Através desta posição privilegiada, o CASB pode aplicar políticas granulares baseadas em múltiplos fatores como identidade do usuário, localização geográfica, tipo de dispositivo, sensibilidade dos dados e contexto da atividade. Por exemplo, um usuário tentando fazer download de um documento financeiro confidencial para um dispositivo pessoal não gerenciado pode ser bloqueado ou redirecionado para uma versão com marca d'água.

O controle de acesso implementado pelo CASB vai além da simples autenticação, incorporando análise contextual e comportamental para determinar se uma tentativa de acesso deve ser permitida. O sistema considera fatores como horário de acesso, localização geográfica, padrões históricos de uso e nível de risco da atividade solicitada.

A funcionalidade de Data Loss Prevention (DLP) do CASB é especificamente adaptada para ambientes de cloud, onde dados podem ser compartilhados, sincronizados e acessados através de múltiplas aplicações e dispositivos. O sistema pode identificar dados sensíveis através de técnicas como classificação automática, fingerprinting de documentos e análise de conteúdo baseada em expressões regulares ou Machine Learning.

A visibilidade de Shadow IT é uma das capacidades mais valiosas do CASB, pois muitas organizações descobrem que seus funcionários utilizam centenas de aplicações SaaS não sancionadas. O CASB identifica essas aplicações através da análise de logs de proxy, DNS e tráfego de rede, fornecendo uma visão completa do uso real de serviços em cloud na organização.

Um exemplo utilizando o CASB é bloquear uploads não autorizados em Dropbox corporativo, um cenário comum de aplicação do CASB envolve o controle de uploads para serviços de armazenamento em cloud como Dropbox, Google Drive ou OneDrive. Considere uma empresa que permite o uso do Dropbox para colaboração, mas precisa prevenir o upload de documentos financeiros confidenciais.

O CASB pode ser configurado para interceptar todas as tentativas de upload para o Dropbox e analisar o conteúdo dos arquivos em tempo real. Utilizando

técnicas de DLP, o sistema identifica documentos que contêm informações financeiras sensíveis baseado em padrões como números de conta bancária, relatórios financeiros ou dados de cartão de crédito.

Quando um upload suspeito é detectado, o CASB pode tomar várias ações: bloquear completamente o upload, permitir o upload, mas aplicar criptografia adicional, redirecionar o arquivo para um repositório corporativo aprovado, ou permitir o upload, mas notificar o departamento de segurança e aplicar marca d'água ao documento.

Além do controle de conteúdo, o CASB também pode aplicar políticas baseadas em contexto. Por exemplo, uploads de documentos sensíveis podem ser permitidos apenas durante horário comercial, de dispositivos corporativos gerenciados, ou de localizações geográficas específicas.

A implementação integrada de CSPM, CWPP e CASB cria uma estratégia de defesa em profundidade que aborda os principais vetores de ataque em ambientes de nuvem. Cada ferramenta contribui com capacidades específicas que, quando combinadas, proporcionam proteção abrangente contra ameaças modernas.

O CSPM atua como a primeira linha de defesa, garantindo que a infraestrutura de cloud esteja corretamente configurada desde o momento da implantação. Esta abordagem preventiva é fundamental porque a maioria das violações de dados em cloud resulta de configurações incorretas, não de sofisticados ataques de hackers.

A prevenção de falhas de configuração através do CSPM opera em múltiplas dimensões. Primeiro, a ferramenta estabelece e mantém um inventário completo de todos os recursos de nuvem, eliminando os "recursos órfãos" que frequentemente passam despercebidos e podem representar vulnerabilidades de segurança. Segundo, implementa verificações contínuas contra benchmarks de segurança estabelecidos, garantindo que novos recursos sejam implantados com configurações seguras.

O impacto da prevenção de configurações incorretas é significativo. Organizações que implementam CSPM relatam reduções de 70-85% no tempo necessário para identificar e corrigir configurações incorretas. Mais importante, a

detecção proativa previne que essas configurações sejam exploradas por atacantes, reduzindo drasticamente o risco de violações de dados.

Enquanto o CSPM protege a infraestrutura, o CWPP foca na proteção das aplicações e dados que executam nessa infraestrutura. Esta camada de proteção é essencial porque mesmo uma infraestrutura perfeitamente configurada pode ser comprometida através de vulnerabilidades na aplicação ou comportamento malicioso em tempo de execução.

A proteção contra exploits implementada pelo CWPP utiliza técnicas avançadas como proteção de memória, prevenção de execução de dados (DEP) e randomização de layout de espaço de endereços (ASLR). Essas técnicas tornam extremamente difícil para atacantes explorarem vulnerabilidades comuns como buffer overflows e ataques de injeção.

A detecção de malware em cargas de trabalho de nuvem requer abordagens especializadas devido à natureza dinâmica e efêmera desses ambientes. O CWPP implementa scanning em tempo real de arquivos e processos, análise heurística para detectar malware desconhecido e sandboxing para execução segura de arquivos suspeitos.

O CASB endereça uma das maiores lacunas de visibilidade em organizações, o uso de aplicações SaaS. Estudos indicam que a organização média utiliza mais de 1.200 aplicações SaaS diferentes, sendo que a maioria não é conhecida ou controlada pelo departamento de TI.

A visibilidade proporcionada pelo CASB vai além da simples descoberta de aplicações. A ferramenta fornece insights detalhados sobre como essas aplicações são utilizadas, quais dados são armazenados ou compartilhados através delas, e quais riscos de segurança elas representam. Esta visibilidade permite que as organizações tomem decisões informadas sobre quais aplicações devem ser sancionadas, bloqueadas ou controladas.

O controle implementado pelo CASB é granular e contextual. Em vez de simplesmente bloquear aplicações inteiras, a ferramenta pode controlar atividades específicas baseadas em políticas sofisticadas. Por exemplo, uma organização pode permitir o uso do Google Drive para colaboração, mas bloquear o compartilhamento

de documentos com endereços de email externos ou o download de arquivos para dispositivos não gerenciados.

A verdadeira força dessas ferramentas emerge quando elas operam de forma integrada, compartilhando informações e coordenando respostas a ameaças.

A integração entre CSPM e CWPP permite correlação entre configurações de infraestrutura e comportamento de cargas de trabalho. Por exemplo, se o CSPM detecta que um grupo de segurança foi modificado para permitir acesso mais amplo, o CWPP pode aumentar o nível de monitoramento das cargas de trabalho afetadas. Paralelamente, se o CWPP detecta comportamento suspeito em uma carga de trabalho, o CSPM pode verificar se há configurações incorretas que facilitaram o ataque.

A integração entre CWPP e CASB é particularmente valiosa para proteger dados em movimento. Quando o CWPP detecta que dados sensíveis estão sendo acessados ou modificados em uma carga de trabalho, pode notificar o CASB para aplicar controles adicionais se esses dados forem posteriormente acessados através de aplicações SaaS.

Quais ferramentas podemos utilizar para estar com uma segurança em nossa cloud?

Quando falamos das ferramentas de CSPM, podemos falar da Prowler. Ela representa uma das soluções open source mais maduras para CSPM, especificamente focada em ambientes AWS com expansão para Azure e GCP. Desenvolvida em Python, a ferramenta implementa centenas de verificações baseadas nos benchmarks CIS (Center for Internet Security) e frameworks de conformidade como PCI DSS, GDPR e HIPAA.

A ferramenta opera através de chamadas às APIs da AWS, utilizando credenciais configuradas localmente ou através de roles IAM, proporcionando uma abordagem agentless que não requer instalação de software nos recursos monitorados.

Temos a Prisma Cloud da Palo Alto Networks, que representa uma das soluções comerciais mais abrangentes do mercado, oferecendo capacidades que vão além do CSPM tradicional para incluir CWPP, CASB e outras funcionalidades de

segurança em cloud. A plataforma suporta mais de 30 provedores de nuvem e serviços, incluindo AWS, Azure, GCP, Alibaba Cloud e Oracle Cloud.

A Azure Defender for Cloud (anteriormente Azure Security Center) é a solução nativa da Microsoft para CSPM e CWPP em ambientes Azure, com capacidades expandidas para ambientes multinuvem. A ferramenta está profundamente integrada ao ecossistema Azure, proporcionando visibilidade granular sobre recursos e configurações específicas da plataforma.

E qual ferramentas podemos utilizar para o CWPP?

O Falco é um projeto open source da Cloud Native Computing Foundation (CNCF) que se tornou o padrão de facto para detecção de ameaças em tempo de execução em ambientes Kubernetes e contêineres. A ferramenta opera no nível do kernel do sistema operacional, utilizando eBPF (extended Berkeley Packet Filter) para monitorar chamadas de sistema e atividades de rede com overhead mínimo.

A arquitetura do Falco é baseada em regras flexíveis que podem ser customizadas para detectar comportamentos específicos. As regras padrão cobrem cenários comuns como execução de shells em contêineres, modificação de arquivos sensíveis, conexões de rede suspeitas e escalção de privilégios

A integração do Falco com ecossistemas Kubernetes é seamless, com suporte nativo para deployment através de Helm charts e operadores. A ferramenta pode enviar alertas para múltiplos destinos incluindo sistemas SIEM, plataformas de mensageria e webhooks customizados. Também podemos falar do Aqua Security, que oferece uma plataforma comercial abrangente para segurança de contêineres e aplicações nativas em cloud.

A solução cobre todo o ciclo de vida de desenvolvimento, desde scanning de imagens durante a construção até proteção runtime em produção. E temos também a plataforma Aqua, que implementa o conceito de "shift-left security", integrando verificações de segurança diretamente nos pipelines CI/CD.

Durante a fase de construção, a ferramenta escaneia imagens de contêiner em busca de vulnerabilidades, malware e configurações incorretas. Na fase de deployment, aplica políticas de segurança que controlam quais imagens podem ser executadas e em quais condições. Já a Trend Micro Cloud One oferece uma suíte integrada de serviços de segurança em cloud que inclui capacidades robustas de

CWPP. A plataforma é projetada para ambientes híbridos e multinuvem, proporcionando proteção consistente independentemente de onde as cargas de trabalho são executadas.

A força do Trend Micro reside em sua experiência em detecção de ameaças e inteligência de segurança. A plataforma utiliza Machine Learning avançado e análise comportamental para detectar ameaças zero-day e ataques sofisticados que podem passar despercebidos por soluções baseadas apenas em assinaturas.

E qual ferramentas podemos utilizar para o CASB?

O mercado de CASB é dominado por soluções comerciais devido à complexidade técnica e aos requisitos de integração com múltiplos provedores de SaaS. Embora existam algumas iniciativas open source, elas geralmente não oferecem a maturidade e abrangência necessárias para ambientes corporativos.

A mais conhecida no mercado é Netskope que é amplamente reconhecida como líder no mercado de CASB, oferecendo uma plataforma abrangente que combina CASB tradicional com capacidades de Security Service Edge (SSE). A arquitetura da Netskope é baseada em uma rede global de pontos de presença que proporcionam baixa latência e alta disponibilidade para usuários em qualquer localização.

A plataforma Netskope oferece cobertura para mais de 7.000 aplicações SaaS, com conectores específicos para aplicações populares como Microsoft 365, Google Workspace, Salesforce e Slack. Para cada aplicação, a ferramenta fornece controles granulares que permitem políticas específicas baseadas em atividades, tipos de dados e contexto de acesso.

Outra alternativa é o Microsoft Defender for Cloud Apps (anteriormente Microsoft Cloud App Security), que oferece capacidades nativas de CASB integradas ao ecossistema Microsoft. A solução é particularmente forte para organizações que utilizam Microsoft 365 e Azure, proporcionando visibilidade e controle profundos sobre esses serviços.

A integração nativa com Azure Active Directory permite que o Defender for Cloud Apps aplique políticas baseadas em identidades e grupos organizacionais existentes. A ferramenta também se beneficia da inteligência de ameaças da

Microsoft, utilizando sinais de segurança de bilhões de dispositivos e serviços para detectar ameaças sofisticadas.

Para começar uma estratégia de segurança em cloud, o primeiro passo é sempre implementar o CSPM, porque ele garante a postura correta da infraestrutura e evita que erros básicos de configuração abram brechas enormes.

Com ele, você descobre recursos expostos, permissões exageradas, senhas fracas e falta de criptografia, corrige o que é crítico e ainda integra ao pipeline de desenvolvimento para prevenir novos problemas. Depois de ter essa base sólida, entra o CWPP para proteger workloads mais sensíveis, principalmente produção e Kubernetes.

Ele observa o comportamento dos containers, identifica desvios, bloqueia ataques e também faz análise de imagens e dependências antes da implantação, trazendo segurança já no desenvolvimento. Na sequência, vem o CASB, que foca no controle do acesso a SaaS e no shadow IT. Ele começa monitorando o uso para entender o que a empresa realmente utiliza e depois aplica políticas graduais, como bloquear uploads em serviços pessoais ou restringir o compartilhamento de documentos.

Essas três frentes não devem ser tratadas como projetos isolados, mas como partes de uma arquitetura de segurança única. Todas precisam mandar eventos para o SIEM, porque só correlacionando informações faz sentido: uma configuração errada, junto com um comportamento anômalo e um acesso suspeito, pode revelar um ataque coordenado.

A resposta deve começar simples, com alertas, e evoluir para bloqueios automáticos quando já houver confiança. O acompanhamento por métricas é essencial para mostrar valor, reduzindo tempo de correção e incidentes enquanto a conformidade melhora.

No fim, segurança em cloud não é só firewall. É postura correta com o CSPM, proteção de workloads com o CWPP e controle de acesso com o CASB. Cada um sozinho pode ajudar, mas o ganho real vem da integração. Esse caminho leva naturalmente ao CNAPP, onde tudo fica unificado e a empresa passa a ter visibilidade e proteção de ponta a ponta.

MERCADO, CASES E TENDÊNCIAS

O mercado de segurança em nuvem está em plena expansão, impulsionado pelo crescimento das arquiteturas multicloud, pela adoção acelerada de aplicações SaaS e pela necessidade de conformidade regulatória em setores críticos, como o financeiro e o de saúde.

De acordo com o relatório [State of the Cloud 2024](#) (Flexera), mais de 80% das organizações já utilizam duas ou mais nuvens, o que amplia os desafios relacionados a visibilidade, governança e proteção contra ameaças avançadas.

Entre as principais tendências, destacam-se o uso de soluções integradas de [Cloud-Native Application Protection Platform](#) (CNAPP), que unem CSPM, CWPP e CASB em uma mesma abordagem, reduzindo a complexidade e melhorando a resposta a incidentes.

O QUE VOCÊ VIU NESTA AULA?

Nesta aula, exploramos os três pilares fundamentais da segurança em cloud. Você aprendeu o contexto que tornou essas ferramentas importantes, analisando como a transformação digital e a adoção em larga escala de tecnologias com cloud criaram novos desafios de segurança que exigem abordagens especializadas.

Mergulhamos profundamente nos conceitos fundamentais de cada ferramenta de CSPM, CWPP e O CASB. Exploramos o ecossistema de ferramentas disponíveis, desde soluções open source como Prowler e Falco até plataformas comerciais abrangentes como Prisma Cloud e Netskope.

REFERÊNCIAS

CLOUDFLARE. **O que é uma plataforma de proteção de carga de trabalho na nuvem (CWPP)?** Cloudflare Learning Center, 2025. Disponível em: <https://www.cloudflare.com/pt-br/learning/cloud/what-is-cwpp/>. Acesso em: 13 out. 2025.

FALCO. **Detect security threats in real time.** 2025. Disponível em: <https://falco.org/>. Acesso em: 13 out. 2025.

GARTNER. **Magic Quadrant for Cloud-Native Application Protection Platforms.** 2024.

GITHUB. **Prowler-cloud.** 2025. Disponível em: <https://github.com/prowler-cloud/prowler>. Acesso em: 13 out. 2025.

IBM. **O que é o Cloud Security Posture Management (CSPM)?** IBM Think, 2025. Disponível em: <https://www.ibm.com/br-pt/think/topics/cspm>. Acesso em: 13 out. 2025.

MICROSOFT. **Gerenciamento de postura de segurança de nuvem (CSPM).** Microsoft Learn, 2025. Disponível em: <https://learn.microsoft.com/pt-br/azure/defender-for-cloud/concept-cloud-security-posture-management>. Acesso em: 13 out. 2025.

NETSKOPE. **What is a Cloud Access Security Broker (CASB)?** Netskope Security Defined, 2025. Disponível em: <https://www.netskope.com/security-defined/what-is-casb>. Acesso em: 13 out. 2025.

PALO ALTO NETWORKS. **What Is Cloud Security Posture Management (CSPM)?** Palo Alto Networks Cyberpedia, 2025. Disponível em: <https://www.paloaltonetworks.com/cyberpedia/what-is-cloud-security-posture-management>. Acesso em: 13 out. 2025.

PALAVRAS-CHAVE

CSPM. CWPP. CASB.

EMANIP



POSTECH